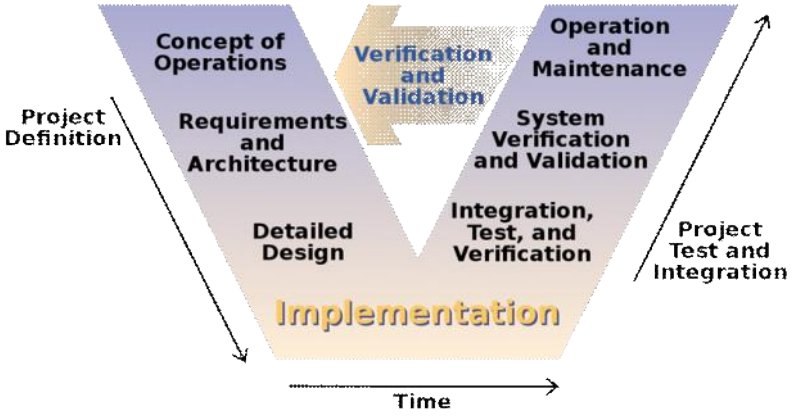
Domain 3: Security Architecture and Engineering

- **To summarize, risk management considerations can be addressed as an integral part of the enterprise architecture by:**
  • Developing a segment architecture linked to the strategic goals and objectives of organizations, defined missions/business functions, and associated mission/business processes;
  • Identifying where effective risk response is a critical element in the success of organizational missions and business functions;
  • Defining the appropriate, architectural-level information security requirements within organization-defined segments based on the organization's risk management strategy;
  • Incorporating an information security architecture that implements architectural-level information security requirements;
  • Translating the information security requirements from the segment architecture into specific security controls for information systems/environments of operation as part of the solution architecture;
  • Allocating management, operational, and technical security controls to information systems and environments of operation as defined by the information security architecture; and
  • Documenting risk management decisions at all levels of the enterprise architecture

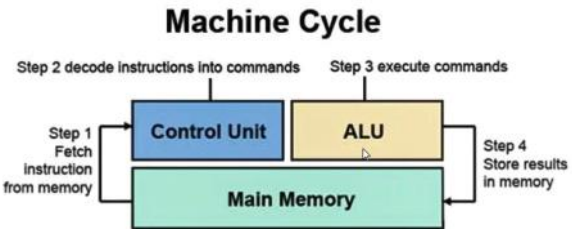
- **Implement and manage engineering processes using secure design principles**
  - Objective
    - **Security must be incorporated and addressed from the initial planning and design phases through the disposal of the system.**
      - Without proper attention to security, an organization's information technology can become a source of significant risk.
      - With careful planning from the earliest stages, however, security becomes an enabler to achieve the organization's mission.
    - Security functions need to be implemented in a manner that prevents their being bypassed, circumvented, or tempered with
    - Security functions need to be invoked whenever necessary to implement the security control
    - Security functions need to be as small as possible so that defects are more likely to be found
  - **ISO/IEC 42010:2007**
      - is an international standard that outlines specifications for system architecture frameworks and architecture languages.
      - It allows for systems to be developed in a manner that addresses all of the stakeholder's concerns.
    - Categories
      - Technical
      - Project
      - Agreement
      - Enterprise

- **SDLC - Software Development Life cycle - this is for software**
- **SELC - System Engineering Lifecycle - this is for system engineering i.e. for Product**
  - The V-Model (System Life Cycle)
  -



- **Key System Engineering Technical process topics** -
- **EXAM POINT (remember which phase comes first/last)**
  - Requirement Definition
  - Requirement Analysis
  - Architectural Design
  - Implementation
  - Integration
  - Verification - is all about whether we met detailed documented requirements.
  - Validation - Weather it met the actual user objectives
  - Transition - To Production
- **Guidelines**
  - When designing and building your system, always assume that it will be under constant attack.
  - Create your security design to be a framework to secure all aspects of your information system
  - Use the principles in security frameworks such as NIST SP 800-14 or SP 800-27 when you design and build your systems

- **Understand the Fundamental Concepts of Security Models**
  - Focus on interactions and provide structure and rules to be followed to accomplish a specific objective (e.g. confidentiality, integrity, and availability).
  - **Control Unit and AU**



- **Fetching** - When the CPU requires data, it retrieves it from memory

- **Decoding** - after fetching next step is decoding, decode the instruction
- **Executing** - after decoding, execute
- **Storing** - Output back to memory
- CPU Is made up of

  The CPU is made up of the

  ■■ Arithmetic Logic Unit (ALU) which is a specialized circuit that is used to perform mathematical and logical operations on the data.

  ■■ Control unit which acts as a mediator controlling processing instructions. The control unit itself does not execute any instructions but instructs and directs other parts of the system such as the registers to do so.

  ■■ Registers which are specialized internal memory holding spaces within the processor itself. These are temporary storage areas for instruction or data and they provide the advantage of speed

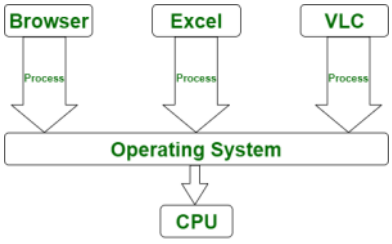
- **CPU States = Very Important**

  The CPU can function in one of four states:

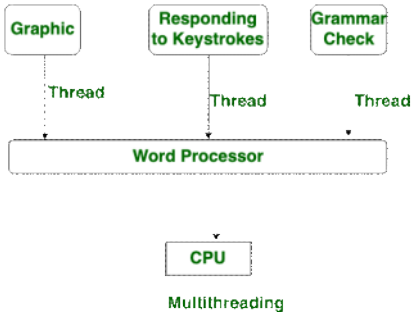
  - **Ready state—Program is ready to resume processing**
  - **Supervisor state—Program can access entire system**
  - **Problem state—Only nonprivileged instructions executed**
  - **Wait state—Program waiting for an event to complete**

- **Exam Question: Fetching -> Decoding -> Executing -> Storing, cycle to repeat until there are no further instructions to be executed.**

- **Increasing Performance**
  - **Multitasking**
    - Is the ability of an Operating System to execute more than one task simultaneously on a single processor at the same time.
  - **Multiprocessing**
    - More than one processer simultaneously on a multiprocessor machine. More than one CPU at a time.
  - **Multithreading**
    - Is the ability of an operating system to execute the different part of a program called threads at the same time.



Multitasking

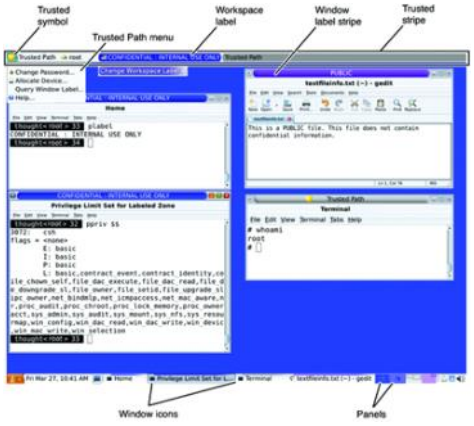


- **TCB (Trusted Computer Base)**
  - **Represents all hardware, software & Firmware in a system coupled with how the system enforces security.**
  - TCB is responsible for **confidentiality and integrity.**
  - The trusted computing base (TCB) of a computer system is the set of all hardware, firmware, and/or software components that are critical to its security, in the sense that bugs or vulnerabilities occurring inside the TCB might jeopardize the security properties of the entire system
  - For example, the memory manager must be tamperproof. When working in kernel mode, the CPU must have the correct logic gates in-place. APIs need to accept only secure requests. And so forth. We have already discussed a 'domain' – within the TCB we call it an execution domain – all TCB components reside in Ring 0 and no one outside of Ring 0 can communicate directly with them
  - **Trusted Computing Base (TCB)**
    - It is the combination of all the security mechanisms within a computer including hardware, software, and firmware and provides a description of trust.
    - Typical Example in Unix System TCB includes Kernel, drivers, firmware, hardware, and services running as root including all programs with SUID root privileges**.**
    - Primary responsibility for TCB is confidentiality & integrity. Enforcing security with hardware, software, firmware and software to build trust.
    - TCB is a concept/service in the OS, firewall, mobile devices, it creates an extra layer of security, enforces centralized access control/security.
    - In Linux: Sudo / SElinux and Windows: run as Administrator
    - **TCB Features**
      - **Trusted Shell:** An isolated user interface via command line that cannot be accessed by external users or observers
      - **Security Kernel:** The hardware, software, etc. that applies the reference monitor.
      - **Reference Monitor** - Enforces (mediate) access controls ensuring people's privileges between objects and subjects.
      - **Execution Domain:** An isolated domain where the TCB can function without external access from other system processes.
      - **Security Perimeter:** A Conceptual line drawn around trusted and untrusted components trusted, separate from one domain to another domain.
      - **Trusted Path:** A trusted connection that cannot be compromised, a connection should be secure.
    - **How TCB Works**
      - The Reference monitor is an abstract machine that is used to implement security.

- The Reference monitor's job is to validate access to objects by authorized subjects
- The Reference monitor operates at the boundary between the trusted and untrusted realm.

- Hardware/Firmware Security Components
  - **BIOS -** Basic Input Output System - Non-volatile firmware
  - **UEFI -** Unified Extensible Firmware Interface - BIOS replacement. Requires firmware updates to be digitally signed
  - **Secure Boot -** Requires trusted attestation
  - **TPM Trusted Platform Module (IMP EXAM)**
    - Trusted Platform Module (TPM) technology is designed to provide hardware-based, security-related functions. A TPM chip is a secure crypto-processor that helps you with actions such as generating, storing, and limiting the use of cryptographic keys. The following topics provide details.
    - Chip that protects cryptographic keys, hashes, and certificates
    - **TPM = Trusted Platform Module**
      - Hardware-based True Random Number Generators (TRNG)
      - **Provide device authentication**
      - **The most common TPM functions are used for system integrity measurements and for key creation and use.**
      - **During the boot process of a system, the boot code that is loaded (including firmware and the operating system components) can be measured and recorded in the TPM.**
      - The integrity measurements can be used as evidence for how a system started and to make sure that a TPM-based key was used only when the correct software was used to boot the system.
      - The TPM is a chip that resides on the motherboard of the device. The TPM serves a number of purposes, including the storage and management of keys used for full-disk encryption (FDE) solutions. The TPM provides the operating system with access to the keys only if the user successfully authenticates. This prevents someone from removing the drive from one device and inserting it into another device to access the drive's data.
    - Proprietary, such as Apple's Secure Enclave Processor (SEP) found in newer iPhones
    - Open standard, such as the Trusted Platform Module (TPM) as specified by the ISO/IEC 11889 standard and used in some laptops and servers.
  - **Hardware Security Module (HSM)** - Device used for crypto processing
  - **Full disk encryption/self-encrypting drives** (**FDE / SED)**
    - Hardware-based mechanism for automatically encrypting magnetic media.
  - **CPU Rings**
    - These are Conceptual boundaries
    - There are multiple RING's each ring has a secure boundary,
      - **Ring 0** - Kernel, CPU, Memory.
      - **Ring 1** - Other OS components
      - **Ring 2** - Communications, Data
      - **Ring 3** - User Applications
    - Higher Ring number, means lower privileges, Compromise Ring 0 - comprising the entire system.

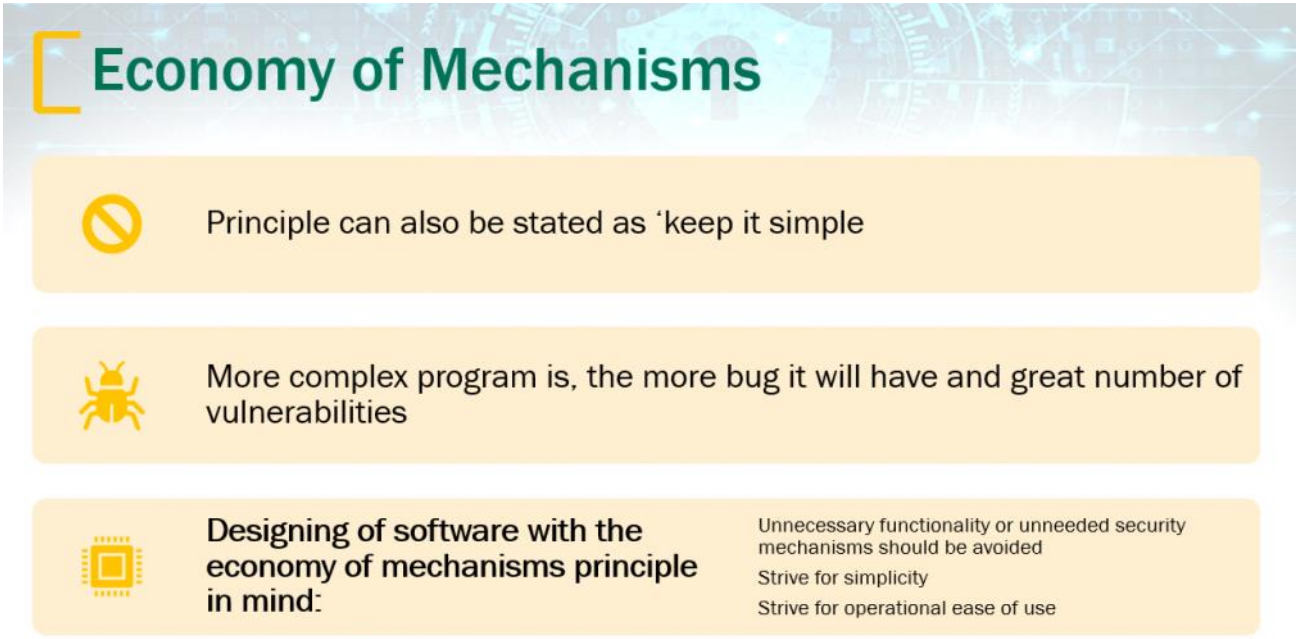
- **Firmware**
  - The Storage of program or instruction in ROM (E.g. BIOS)
  - Typically embedded into hardware and is used to control that hardware.
  - Nonvolatile
  - It is a limited device, and it is difficult to extract information for firmware as it is read-only in nature.
- **Single point of failure (SPOF)**
  - It can be any technology component whose failure impacts the availability of the entire system.
  - SPOFs can be anywhere in the dependency chain
  - Need to identify SPOF and their business impact
  - Investments in system survivability using high availability and fault-tolerant technologies



- **Secure Memory Management (IMP EXAM POINT)**
  - Primary storage
    - RAM, ROM, SDRAM, data being processed or waiting to be processed, location of data refers to the physical address, could be RAM, Cache or Registers.
    - Location where the data is stored called Physical Memory Address, deal with investigation obtain the evidence from the primary storage, retrieve information from memory.
    - Shutdown and restart, he might lose the information. Last access information stored in memory.
  - **Secondary Storage**
    - Hold information until it is deleted, or overwritten, does not require power to keep data, large capacity at a low price, usually slower than primary, use to store files, programs and data, HDD, Magnetic tapes, optical disks, and USB
  - **Virtual Memory**
    - Implemented using hardware and software, maps virtual address to physical address, taken from physical HDD, its managed by OS, use the memory management unit or MMU, allows you to exceed the amount of RAM, frees the application from memory management, make use of paging and swapping.
    - **Volatile Memory**
      - Requires power to maintain information e.g. RAM
      - Usually Used for Primary storage

        - Faster than secondary storage
        - Loses the data when powered off
    - **Non Volatile Memory**
        - Keeps information even when power is off
        - Your Read-Only Memory (ROM), Flash memory on devices
        - Hard Disks, Magnetic Tape, Optical Discs, USB Storage
        - Usually Used for Secondary storage.

- Memory Protection **(IMP EXAM)**
    - The main purpose of memory protection is to prevent a process from accessing memory that has not been allocated to it.
    - **The three most common ones are segmentation, paging, and protection keying.**
    - A protection key mechanism divides physical memory up into blocks of a particular size, each of which has an associated numerical value called a protection key.
    - Prevent a process from accessing memory that has not been allocated to it
        - **Isolation:** process isolation is a requirement for multilevel security mode systems, defines the memory address, executes it in a particular location.
        - **Segmentation:** Enforces the requirements via physical hardware controls rather than logical process isolation controls forced by the OS. segmentation of the memory.
        - **Firmware:** The storage of programs or instructions in ROM, Typically embedded into hardware is used to control the hardware, non-volatile.
    - **Address Space Layout Randomization (ASLR)**
        - If you recall, before a process can execute, it must be loaded into memory at a specific memory address. For most memory exploits and malware to be successful, the attacker will need to know that memory address. While it might seem very unlikely how a remote attacker could gain such information, early on it became obvious that processes tended to be loaded into the same memory location each time due to the desire of an OS to optimize memory use.
        - Address space layout randomization, or ALSR, is a memory management technique implemented at the OS level and is designed to change up the memory locations that a given process would be loaded into. ALSR has been implemented in both the Windows and Linux operating systems
- **Security Capabilities of Information Systems**
    - Processor States
        - Provide one of the first layers of defense, provide specialized processors for security functions, have states that can distinguish between more than less privileged instructions
        - **Support at least two states: Supervisor mode (Kernel-mode) and Problem(User mode)**
    - Layering
        - The organization of programming into separate functional components that interact in some sequential and hierarchical way
        - Helps ensure that volatile or sensitive areas of the system are protected from unauthorized access or change
        - The purpose of layering is to
            - Create the ability to impose specific security policies at each layer
            - Simplify functionality so that the correctness of its operation is more easily validated
- **Economy of Mechanism**



- **likelihood of a greater number of vulnerabilities increases with the complexity of the software architectural design and code**

  Taken into account, the following considerations support the designing of software with the economy of mechanisms principle in mind:

- ■■ *Unnecessary functionality or unneeded security mechanisms should be avoided.* Since patching and configuration of newer software versions has been known to security features that were disabled in previous versions, it is advisable to not even design unnecessary features, instead of designing them and leaving the features in a disabled state.
- ■■ *Strive for simplicity.* Keeping the security mechanisms simple ensures that the implementation is not partial, which could result in compatibility issues. It is also important to model the data to be simple so that the data validation code and routines are not overly complex or incomplete. Supporting complex, regular expressions for data validation can result in algorithmic complexity weaknesses as stated in the Common Weakness Enumeration publication 407 (CWE-407).
- ■■ *Strive for operational ease of use.* Single Sign On (SSO) is a good example that illustrates the simplification of user authentication so that the software is operationally easy to use.

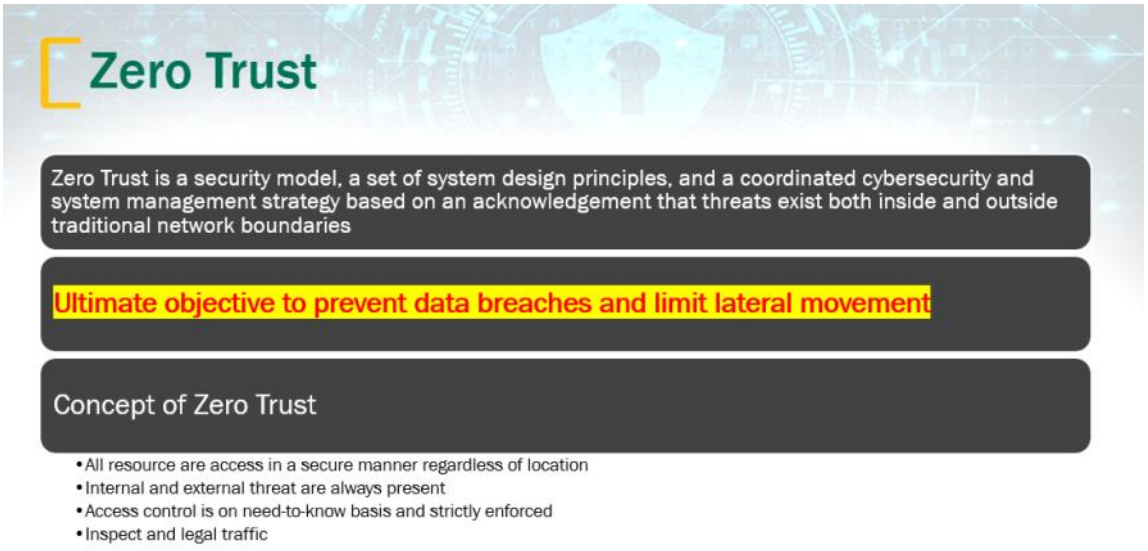
- **Privacy by Design**
  - **is a framework based on proactively embedding privacy into the design and operation of IT systems, networked infrastructure, and business practices.**



- Proactive not reactive—preventative not remedial
- Lead with privacy as the default setting
- Embed privacy into design
- Retain full functionality (positive-sum, not zero-sum)
- Ensure end-to-end security
- Maintain visibility and transparency—keep it open
- Respect user privacy—keep it user-centric

- [YouTube link for privacy by design]

- **Zero Trust**

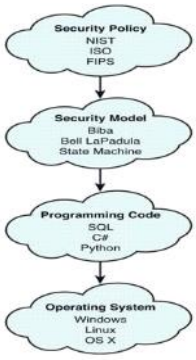


- Zero Trust is a security concept centered on the belief that organizations should not automatically trust anything inside or outside its perimeters and instead must verify anything and everything trying to connect to its systems before granting access.
- The fundamental purpose of Zero Trust is to understand and control how users, processes, and devices engage with data
- Never trust but verified before give access
- zero trust networking can only work if real-time vetting and visibility into user activities is maintained.

- **Enterprise Architecture**
  - Defines how computing components are built, connect and communicate and define how services get from the system to the user.
  - **Enterprise Security Architecture**
    - The manner in which security controls are designed, implemented, and integrated into the system architecture is called **Security Architecture**.
      - Implements building blocks of information security infrastructure across organizations.

        - Focused on setting long-term strategy for security services in the enterprise
        - Establishes priorities for security services development
    - The subset of Enterprise architecture is Security architecture.
        - Enterprise architecture: Ex: TIGAG, Zachman
        - Security architecture : SABSA, CISSP-ISSAP,EP,MP
    - ESA has the following goal
        - Provide a long-term, simple view of your controls.
        - Provide a unified vision for common security controls across the organization.
        - Maximize existing technology investments.
        - Be flexible in addressing current and future threats.
        - Always support the core needs of the organization
    - Enterprise Security Architecture Benefits **(EXAM IMP)**
        - Outlining general security strategy.
        - Providing guidance when making technical decisions.
        - Providing decision-makers with good guidance to make security-related design decisions and investments.
        - Limiting future technological needs to a realistic set of proposed services.
        - Being able to implement industry standards and best practices.
        - Managing risk consistently across the enterprise.
        - Reducing costs by providing reusable common security services.
        - Aligning the overall security strategy to support business goals.
    - **Intended Benefits (EXAM IMP)**
        - Enable decision-makers to make better security-related investment and design decisions
        - Establish future-state technology architecture focused on a limited set of proposed security services.
        - Supports, enable and extend security policies and standards
        - Describe general security strategies used to guide security-related decisions at the technical architecture and solution levels.
        - Manage IT Solution risk consistently across the project while leveraging industry best practices
        - Reduce cost and improve flexibility by implementing reusable, common security services.
        - Provide a secure mechanism for end-of-life and decommissioning solutions when necessary.

- **Security Models (Information Systems Security Evaluation Models) EXAM IMP**
    - Security Policy: Documents the security requirements
    - Security models define rules of behavior for an information system to enforce policies related to system security but typically involving confidentiality and/or integrity policies of the system.
    - Formal Security Model: Describes and verifies the ability to enforce security policy in mathematical or measurable terms.
    - **Policy - outlines the goal**
    - **Models - Framework**



- **Bell-LaPadula Confidentially Model (V.IMP EXAM)**
  - The Bell–LaPadula (BLP) model is intended to address **confidentiality** in multilevel security (MLS) system
  - The model system uses labels to keep track of clearances and classifications and implements a set of rules to limit interactions between different types of subjects and objects
  - **The security model responsible for confidentiality is Bell-LaPadula**
  - Use in the defense department
  - First mathematical model used by US DOD & Documented in Orange book.
  - The Bell-LaPadula model is also referred to as **the Lattice-based mode**l (multi-layer model) (or) State machine model.
  - The model defines two properties,
    - **Simple Security property (ss-property)**
      - A subject cannot read/access an object of a higher classification **(no read up)**
      - **E.g. Engineer/Support person can't read/access data above his classification**
    - **Star property**
      - A subject can only save an object at the same or higher classification **(no write down)**
      - **E.g. . Sr. Mgt can't save/write document below in Classification**
  - Prevent the exposure or unauthorized disclosure of information
- **Biba (EXAM IMP)**
  - The Biba model is designed to address **data integrity** and does not address data confidentiality.
  - Integrity of information is being maintained by preventing corruption.
  - Multilevel approach to integrity designed to prevent unauthorized subjects from modifying objects
  - **This Security model responsible for Integrity.**
  - The model defines three properties
    - **Simple Integrity property**
      - A subject cannot observe an object of lower integrity **(no read down)**.
      - **E.g. . Sr. Mgt can't observe the document below in Classification**
    - **Star property**
      - A subject cannot modify an object of higher integrity **(no write up)**
      - **E.g. Engineer/Support person can't modify data above his classification**
    - **Invocation property**
      - A subject cannot send logical service requests to an object of higher integrity

        - No Read Up (Bell-Lapadula) No Read Down (Biba)
        No write down (Bell-Lapadula), No write up (Biba)

- **Clark-Wilson Integrity Model**
  - The Clark–Wilson model improves on Biba by **focusing on integrity at the transaction level** and addressing three major goals of integrity in a commercial environment.
- First commercial model
- Requires well-formed transactions and separation of duty
  - Well-Formed Transactions
    - Constraints on user to ensure the internal consistency of data is not affected.
  - Separation of duties
    - Ensure the consistency of data
- Prevent user from making improper modification
- Forces collusion to commit fraud
- **Brewer-Nash (The Chinese Wall)**
  - The Chinese Wall model provides a dynamic access control depending on the user's previous actions.
  - This model prevents conflict of interests from members of the same organization to look at the information that creates a conflict of another member of that organization.
  - Is needed in the DevOps framework
  - **Conflict of interest -- Ans Brewer-Nash**
  - Example **SDLC**

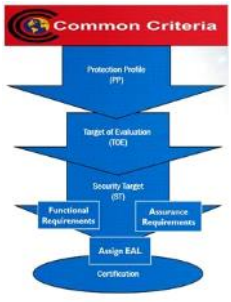
- **Exam Point to Remember**

  Question talks about **Well-formed Transaction - Clark-Wilson**
  Question talks about preventing a **conflict of interest - Brewer-Nash**
  Question talks about **SDLC security model - Brewer-Nash**
  Question talks about **confidentiality/subject-to-object/deals with access - Bell-LaPadula**
  Question talks about **integrity - Biba**
- **Confidentiality - deals with access - Sensitivity**
- **Integrity - deals with the process - Criticality**
- **Controls Based Upon Systems Security Requirements**
- **Evaluation Criteria**
  - Each control should include specific evaluation methods and expected results.
  - Controls may be evaluated by multiple methods
- **Certification & Accreditation**
  - Certification is the technical evaluation of the security components within the product.
    - Evaluation criteria must be chosen (TCSEC or CC)
    - **Certification process will test the system's hardware, software, and configuration in a production-like environment**
    - Results of the evaluation become a baseline to compare against the set of specific security requirements
    - If the certification is positive, the system enters the next phase of evaluation.
  - Accreditation is the formal acceptance of the product's overall security by management.
    - **If management determines that the needs of the system satisfy the needs of the organization, they will formally accept the evaluated system, usually for a defined period or set of conditions.**
- **Important Areas**

1. **Assurance**
2. **Certification**
3. **Accreditation**
4. **Acceptance**

- **Standards for Evaluate the product**
  - **Trusted Computer System Evaluation Criteria (TCSEC)**
    - Primary objective is Confidentiality and some parts of integrity.
    - U.S DoD standard that sets basic standards for the implementation of security protections in computing systems
    - Primarily intended to help the DoD find products that met those basic standards.
    - Strongly focused on enforcing confidentiality with no focus on other aspects of security such as integrity or availability
    - Superseded by the common criteria

- **Common Criteria**
  - ISO15408 another name for CC, the standard was the first truly international product evaluation criteria.
  - Purpose of the certification is the evaluated the product and give universal acceptance to the product
  - Basically, use to evaluate the product independently
  - The Common Criteria provides a structured methodology for documenting security requirements, documenting and validating security capabilities, and promoting international cooperation in the area of IT security.
  - Use of the Common Criteria “protection profiles” and “security targets” greatly aids in the development of products and systems that have IT security functions.
  - The Common Criteria evaluates products against a protection profile and results are published Common Criteria Lab evaluates different types of ICT products, for each of these products they have separate protection profiles.
  - The Common Criteria introduced Protection Profile (PP)
    - Common set of functional and assurance requirements for a category of vendor products deployed in a particular type of environment.
  - The Protection Profiles has three important elements.
    - SPD Security Problem Description - ex: firewall address specific risk
    - SO security objectives - ex: will it meet the objectives / what controls
    - SR security requirements - ex: specific requirements for compliance
  - Exam notes
    - We are evaluating functional assurance so we can allocate evaluation assurance
- The Common Criteria (ISO 15408)



- **Target of Evaluation (ToE)**
  - Product Proposed to provide needed Evaluation
  - Protection Profile
    - Description of needed security protection
    - set of security requirements associated with a class of products, i.e., firewalls have PPs and operating systems have PPs, but these may differ
    - PPs help streamline the comparison of products within product classes
    - Protection profiles (PPs) specify for a product that is to be evaluated (the TOE) the security requirements and protections, which are considered the security desires, or the "I want," from a customer.
    - The output of the Common Criteria process is an Evaluation Assurance Level (EAL), a set of seven levels, from 1, the most basic, through 7, the most comprehensive. The higher the EAL value, the higher the degree of assurance that a TOE meets the claims. Higher EAL does not indicate greater security.
  - Security Target Written by vendor explaining Security functionality & assurance mechanism that meet security solution.
    - Security targets (STs) specify the claims of security from the vendor that are built into a TOE. STs are considered the implemented security measures, or the "I will provide," from the vendor. In addition to offering security targets, vendors may offer packages of additional security features.
  - Packages Requirements are bundled in to packages for reuse
- Links video to understand
  https://www.youtube.com/watch?v=ceg4hyrcHJc&t=120s
- **Evaluation Assurance Level**
  - Evaluation Assurance Level is a category ranking assigned to an IT product or system after a Common Criteria security evaluation.
  - The level indicates to what extent the product or system was tested.
  - A higher EAL does not indicate a higher level of security than a lower EAL because they may have different functional features in the Security Targets.
  - **Standard EAL Package (Sure Shot in Exam)**
    - **EAL 1 - Functionally tested**
    - **EAL 2 - Structurally tested**
    - **EAL 3 - Methodically tested and checked**
    - **EAL 4 - Methodically designed, tested, and reviewed**
    - **EAL 5 - Semi-formally designed and tested**
    - **EAL 6 - Semi-formally verified design and tested**
    - **EAL 7 - Formally Verified Designed and Tested**

      For Sure My Mother - So Sweet Forever

- **Select Controls and countermeasures based upon information systems security standards**
  - ISO/IEC 27001 and 27002 Security Standards
    - Universally recognized for sound security practices.
    - ISO/IEC 27001:2013 focused on the standardization and certification of an organization's ISMS.
    - ISO/IEC 27002 is code of Practice for Information security management used to

support/implement 27001, often used in tandem with 27001:2013, lists control objectives, recommended a range of specific security controls according to best practice.

- Key areas of Focus
  - General requirements of the ISMS
  - Management Responsibility
  - Internal ISMS audits
  - Management review of the ISMS
  - ISMS improvement

- **Control Objectives for Information and Related Technology (COBIT)**
  - Is a control framework for employing information security governance best practices within an organization.
  - COBIT was developed by ISACA (Information Systems Audit and Control Association)
  - the purpose of COBIT is to provide management and business process owners with information technology (IT) governance model that **helps in delivering value from IT and understanding and managing the risks associated with IT**.
  -

- **Architecture-Based Risks**
  - **Emanation Security**
    - Device monitors the signals/intercepts the information.
    - Countermeasure **TEMPEST** physical control
      - TEMPEST is a National Security Agency specification and a NATO certification referring to spying on information systems through leaking emanations, including unintentional radio or electrical
    - **TEMPEST countermeasures include Farady cage, white noise, control zones**
      1. Faraday Cage
         1) A closed enclosure with external metal mesh that fully surrounds the enclosure absorbing EM signals • They are quite effective in blocking EM signals
      2. White Noise
         1) Broadcasting false traffic at all times to mask and hide presence of real emanations • Most effective when created around the perimeter of an area so that it is broadcast to protect the internal area where emanations may be needed
      3. Control Zones
         1) Implementation of zones such that the emanations are controlled within the environment; can use faraday cage or white noise in those zones

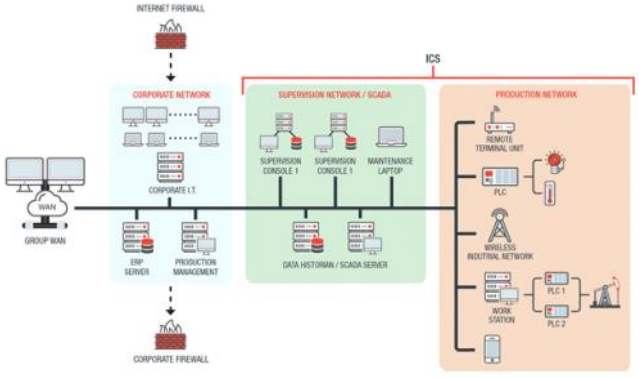
- **Channel Attacks**
  - Covert channel (Closed)
    - Communication mechanisms are hidden from the access control and the standard monitoring system of an information system
    - May use irregular methods of communication to transit information.
    - A legitimate way of exploiting, without permission Ex: Trojan
    - Goal is to reach **Confidentiality**
    - The TCSEC identifies two types of covert Channel

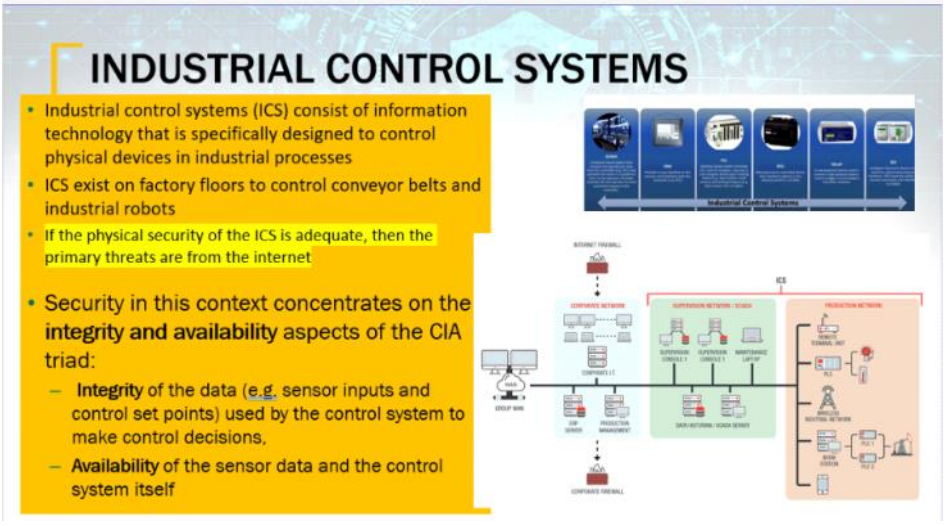
        - Storage
            - Attacker trying to use free memory, trying to execute from free memory, storage channel communicate via stored objects.
        - Timing
            - Modify the timing of an event without the user's knowledge. Time of Check and Time of Use modify system activity (TOC) and (TOU) attack, Asynchronous attacks.
    - Overt channel (Open)
        - Encryption directly interacting.

- **Assess and mitigate vulnerabilities in embedded devices**
    - Embedded systems are used to provide computing services in a small form factor with limited processing power.
    - An embedded system is an electronic product that contains a microprocessor and software designed to perform a specific task. An embedded system can be either fixed or programmable.
    - Embedded systems are found in consumer, cooking, industrial, automotive, medical, commercial, and military applications.
    - Embedded systems range from very small personal devices to large-scale environments. For example, digital watches, health meters, printers/MFDs, camera systems, routers, sensor traffic lights, automotive safety, and industrial control systems.
    - The Internet of Things (IoT) sensors and actuators embedded in physical objects—from roadways to pacemakers—are linked through wired and wireless networks provide a pathway for attack
    - Security concerns for embedded systems include the fact that most are designed with a focus on minimizing cost and extraneous features
    - embedded system may be in control of a mechanism in the physical world, a security breach could cause harm to people and property.
    - **Cyber-Physical system**
        - Internet of Things (IoT)
            - The Internet of Things (IoT) refers to small internet-connected devices, such as baby monitors, thermostats, cash registers, appliances, light bulbs, smart meters, fitness monitors, cars, etc., etc. Many of these devices are often directly accessible via the internet.
            - Internet Capable devices outside the normal Information Systems component.
            - Mirai Botnet Attack and Revenge of the Internet of Things
            - **Availability biggest concern in IoT, Denial of Service attack is a common attack**
            - **IOT should be segregated for the network as if any system compromise would network is attacked.**
            - Limited functionality OS
            - May interface with the physical world
            - Pervasive and often connected to a general-purpose network.
            - Functions/Accessibility may be unclear to owner/user
            - Security
                - IoT devices should be protected as endpoints.
                - IoT systems should be segmented and isolated from core infrastructure.
                - Change Default credentials.
                - Keep devices updated with the latest firmware releases.

    - Keep IoT Devices behind NAT.
- Concern, limited vendor support for an update
- Little to no onboard security capability
- Poor Code management due to the rapid development cycle.
- **Authentication** IoT usually have very poor authentication mechanisms
- **Encryption** IoT devices with limited processing power seldom include any type of encryption, as it is very expensive in terms of resources.
- **Updates** many IoT vendors do not implement any type of automatic updating of their devices.
- **IOT Mitigation**
    - Change default credentials soon as possible, and before you connect device to Internet
    - Keep your device updated with current firmware release, either by enabling auto-update or by periodically checking with the manufacture's website for a firmware update.
    - Don't place IoT devices on the Open internet but behind the firewall so that they are not directly accessible externally.
    - Keep IoT Device behind NAT

- **Industrial Control System (ICS)**





- Industrial systems and critical infrastructures are often monitored and controlled by simple computers called industrial control systems (ICS).
- ICSs are used to control industrial processes such as manufacturing, product handling, production, and distribution.
- **Security in this context concentrates on the integrity and availability aspects of the CIA triad:**

    - **Integrity of the data (e.g. sensor inputs and control setpoints) used by the control system to make control decisions.**
    - **Availability of the sensor data and the control system itself.**
- Three well-known types of ICS systems
    - Supervisory control and data acquisition (SCADA)
        - A SCADA system can be typically viewed as an assembly of interconnected equipment used to monitor and control physical equipment in industrial environments.
        - SCADA system can operate as a standalone device, be networked together with other SCADA systems, or be networked with traditional IT systems
        - SCADA is used to monitor and control a wide range of industrial processes,
        - SCADA can communicate with PLCs and DCS solutions
        - Generally, typical security management and hardening processes can be applied to ICS, DCS, PLC, and SCADA systems to improve on whatever security is or isn't present in the device from the manufacturer. Common important security controls include isolating networks, limiting access physically and logically, restricting code to only essential application, and logging all activity
        - The ISA99 standards development committee has established and is maintaining guidelines for securing ICS, DCS, PLC, and SCADA systems

    - Distributed control systems (DCSs)
        - Typically confined to a geographic area or specific plant (e.g., manufacturing facility).
        - DCS focuses on processes and is state driven, whereas SCADA focuses on datagathering and is event driven. A DCS is used to control processes using a network of sensors, controllers, actuators, and operator terminals and is able to carry out advanced process control techniques. DCS is more suited to operating on a limited scale, whereas SCADA is suitable for managing systems over large geographic areas.

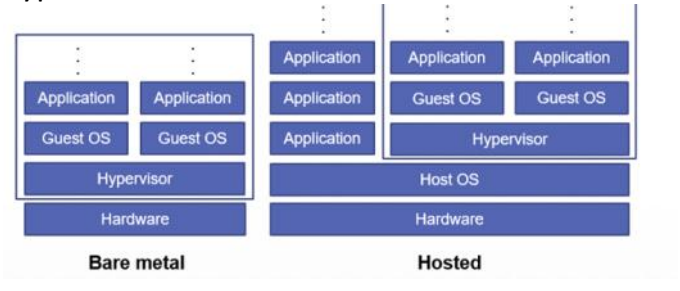
    - Programmable logic controllers (PLCs)
        - Ruggedized industrial controller.
        - PLC units are effectively single-purpose or focused-purpose digital computers. They are typically deployed for the management and automation of various industrial electromechanical operations, such as controlling systems on an assembly line or a large-scale digital light display
- The Protocol used in the ICS network is DNP3 - Converged Protocol (Distributed Network Protocol)
- Vulnerabilities
    - Limited functionality
        - Standard OS functions and protections may not be available.
    - Limited protections
        - General-purpose host protections are not feasible.
    - Long lifespan (become outdated)
        - Typically in operation for 10+ years.
    - Susceptible to misuse/error
        - Complicated, specialty systems, difficult to validate correct code and configuration

- Highly susceptible to denial of service (DoS) attacks:
- Attacks can produce physical effects
  - Unlike most computing systems, attacks can cause impacts to the physical world.
- Often unattended in remote locations
  - Physical security may be limited or unmonitored allowing attackers to gain and maintain physical access with limited effort.
- **OPC/DCOM Attacks (Very Important**
  - OPC is a real-time data communications standard based in these services. Many installations are moving away from the Microsoft-based OPC model; however, many still commonly use OPC for efficient connectivity with diverse ICS equipment. Also, organizations still widely deploy OPC on mission critical components of a control system environment, such as HMI workstations and historians, highlighting a continued dependency on OPC.
  - A recent study showed that many ICSs and their processes would have permanent historical data and production time loss if an OPC service was to become unavailable.
  - OPC standards and application programming interfaces (APIs) that are common in control system environments are OPC Data Access, OPC Alarms, OPC Data Exchange, and OPC Data-XML
  - These vulnerabilities expose many ICSs to critical risks such as the installation of undetected malware, denial-of-service attacks, escalated privileges on a host, and/or the accidental shutdown of ICSs because of an overload flaw

- **ICS Security**
  - Isolated network infrastructure:
    - The most effective mitigation is to ensure limited functionality components are not connected or exposed to general-purpose networks and are only connected to highly controlled networks.
  - Robust network connection restrictions and monitoring:
    - Any Connection allowed on or off must be carefully monitored.
  - Highly segmented network
    - Networks segmented by process or by devices that must directly communicate to function. This generates some very small network segments but is highly desirable.
  - Protect communication channels:
    - All communication channels must be heavily protected from outside access.
  - Robust configuration control
    - Configuration and code on devices must be robustly managed.
  - If the physical security of the ICS is adequate, then the primary threats are from the internet. In that case, a reasonable and common compensating control is to air-gap the networks used by the industrial control devices
  - For ICSs that must be remotely accessible, compensating controls such as installing a web proxy or VPN should be considered to add an additional layer of security on top of whatever access controls are implemented on the ICS itself.

- **Five Key Security Countermeasures for Industrial Control Systems**
  - Here are five key countermeasures that organizations can use to drive activities in ICS environments. Applying these steps will pave the way toward a more robust security environment and significantly reduce the risk to operational systems.
    - Identify, minimize, and secure all network connections to the ICS.
    - Harden the ICS and supporting systems by disabling unnecessary services, ports, and protocols; enable available security features; and implement robust configuration management practices.
    - Continually monitor and assess the security of the ICS, networks, and interconnections.
    - Implement a risk-based defense-in-depth approach to securing ICS systems and networks.
    - Manage the human—clearly identify requirements for ICS; establish expectations for performance; hold individuals accountable for their performance; establish policies; and provide ICS security training for all operators and administrators.

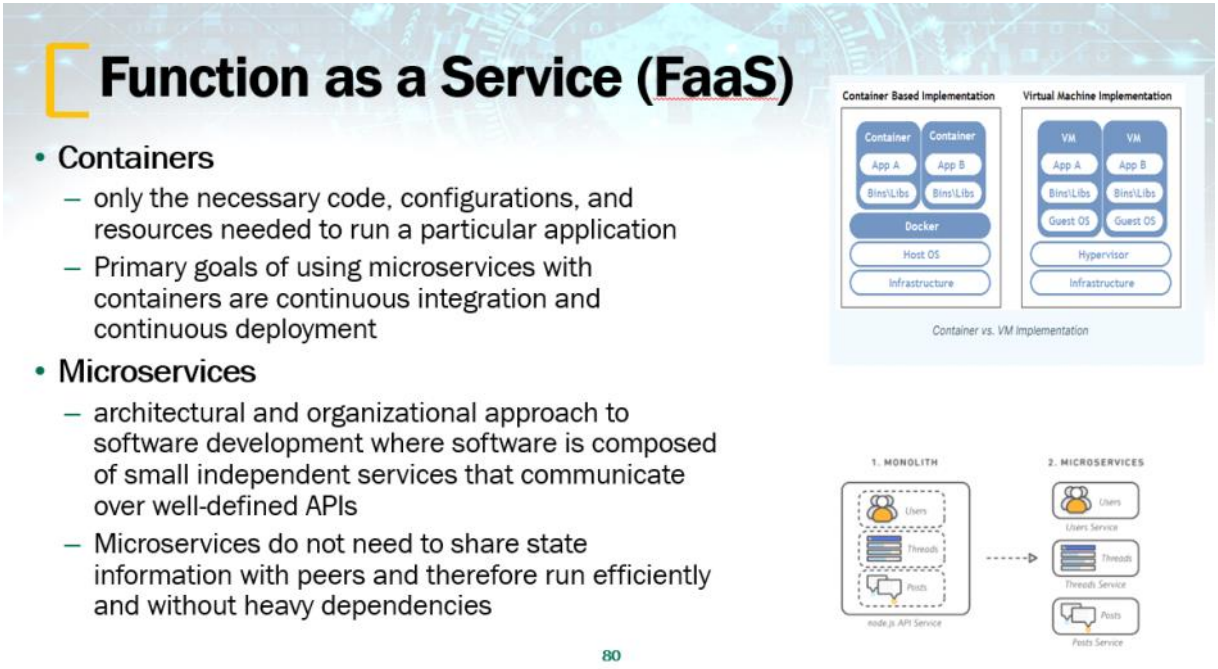
- **Virtualization**
  - Virtual machines are typically isolated in a sandbox environment and if infected can quickly be removed or shut down and replaced by another virtual machine.
  - Code executing within the environment is strictly limited from direct interaction outside the environment.
  - Permission for system access may be restricted independently for each virtualized or sandboxed instance.
  - **Type 1 - Bare metal server -> Hypervisor -> VM**
    - A type I hypervisor is a native or bare-metal hypervisor. In this configuration, there is no host OS; instead, the hypervisor installs directly onto the hardware where the host OS would normally reside.
    - Type 1 hypervisors are often used to support server virtualization. This allows for maximization of the hardware resources while eliminating any risks or resource reduction caused by a host OS.
  - **Type 2 (Hosted)**
    - Bare metal server -> OS -> VMWare workstation -> VM
    - A type II hypervisor is a hosted hypervisor In this configuration, a standard regular OS is present on the hardware, and then the hypervisor is installed as another software application.
    - Type II hypervisors are often used in relation to desktop deployments, **where the guest OSs offer safe sandbox areas to test new code**, allow the execution of legacy applications, support apps from alternate OSs, and provide the user with access to the capabilities of a host OS.
  - Type 2 is more vulnerable than Type 1, with more functionalities more chances.
  - Type 1 is more secure

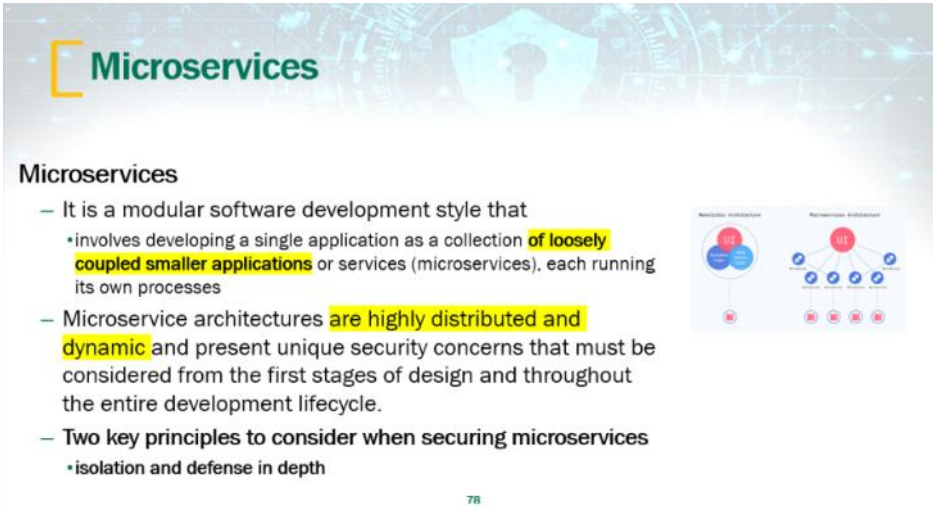


- The advantages of virtualization include the following
  - More efficient use of the underlying hardware
  - Dynamic scaling of infrastructure in response to demand
  - Additional separation and isolation between programs and applications running
- **Vulnerabilities of Security Architectures, Designs, and Solution Elements**
  - The vulnerabilities and mitigations are not intended to be comprehensive for each system type and represent the most common issues and solutions associated with the system type.
  - Top Threats and Mitigations
    - Top Threat Actions
      - **Hacking:** Human action attempting various permutations of actions to defeat or bypass system protections or system security.
      - **Social engineering:** Attempting to gain information or access by impacting human behavior or process. Generally implemented through human interaction but maybe message or communication-based.
      - **Malware distribution:** Manual or automated distribution of malware. It may be targeted, untargeted, or the result of self-replicating malware moving autonomously.
      - **Phishing:** Attempting to gain information or access by sending messages (e.g., email) that seem to be legitimate but are not. May be combined with types of social engineering or malware distribution.
    - Top Mitigations
      - **Know what you have**: Maintain a good inventory of all IT operating in the environment and understand the operational status. While this sounds simple, it is one of the most difficult things to accomplish for most large organizations.
      - **Patch and manage what you have:** Keep hardware, firmware, and software up to date and manage system configurations to ensure they are kept in a secure and well-maintained state. This is a basic security function but is also commonly neglected and not well implemented in many organizations.
      - **Assess/monitor/log:** Assess system security status, monitor the status continuously, and log system, user, and process actions to the greatest extent possible. At the enterprise level, this includes collecting and aggregating individual system logs with automated and manual reviews.
      - **Educate users:** At the enterprise level, this is critical to address human-based attacks (social engineering, phishing, etc.) that technology alone cannot defend against.

- **Server Hardening Guidelines**
  - Installing updates and patches.
  - Removing Or locking unnecessary data.
  - Changing Default password
  - Enabling logging & Auditing.
  - Changing default system, file system services & network configuration as needed to improve security.

- **Function as a Service**

- 

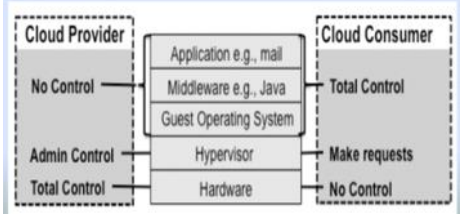
- 

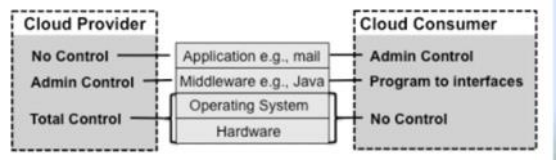
- **Cloud**

  - **Cloud Computing**
    - Shift of Capex to Opex
    - A Model for enabling ubiquitous convenient, on-demand network access to a shared pool of configurable computing resources that can rapidly be provisioned and released with minimal management efforts or service provider interaction. This cloud model is composed of five essential characteristics, three service models, and four deployment models. - NIST
    - NIST's 5 Requirement of Cloud Computing
      - On-Demand Self Service
        - A consumer can unilaterally provision computing capabilities, such as server time and network storage, as needed automatically without requiring human interaction with each service provider.
      - Broad Network Access
        - Capabilities are available over the network and accessed through standard mechanisms

that
promote use by heterogeneous thin or thick client platforms (e.g., mobile phones, tablets, laptops, and workstations).

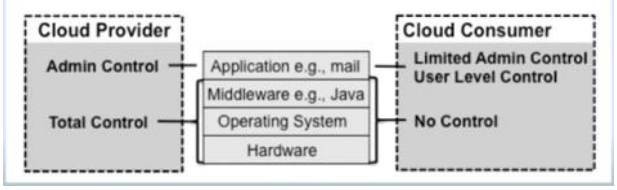
- Resource Pooling
  - The provider's computing resources are pooled to serve multiple consumers using a multi-tenant model, with different physical and virtual resources dynamically assigned and reassigned according to consumer demand
- Rapid Elasticity
  - Capabilities can be elastically provisioned and released, in some cases automatically, to scale rapidly outward and inward commensurate with demand.
- Measure Service
  - Cloud systems automatically control and optimize resource use by leveraging a metering capability at some level of abstraction appropriate to the type of service (e.g., storage, processing, bandwidth, and active user accounts).

- **Cloud Service Models**
  - **Infrastructure as a service (IaaS)**
    - The capability provided to the consumer is to provision processing, storage, networks, and other fundamental computing resources where the consumer can deploy and run arbitrary software, which can include operating systems and applications.
    - The consumer does not manage or control the underlying cloud infrastructure but has **control over operating system storage, and deployed applications; and possibly limited control of select networking components (e.g., host firewalls)**.
    - 

  - P**latform as a Service (PaaS)**
    - The capability provided to the consumer is to deploy on to the cloud infrastructure consumer-created or acquired applications created using programming languages, libraries, services, and tools supported by the provider.
    - The consumer does not manage or control the underlying cloud infrastructure, including network, servers, operating systems, or storage but has to **control over the deployed applications and possibly configuration settings for the application-hosting environment**.
    - 

  - **Software as a Service (SaaS)**
    - The capability provided to the consumer is to use the provider's applications running on a cloud infrastructure. The applications are accessible from various client devices through either a thin client interface, such as a web browser (e.g., web-based email), or a program interface.
    - The consumer does not manage or control the underlying cloud infrastructure, including

network, servers, operating systems, storage, or even individual application capabilities, with the possible exception of limited user-specific application configuration settings.



- **Security-as-a-Service (SECaaS)**
  - It is the delivery of managed security services for public, private, and hybrid cloud environments
  - SECaaS or relieves the burden of relying on the SaaS, PaaS, or IaaS vendor for security protection and enforcement.
  - Services include encryption, activity monitoring, DLP, malware detection, filtering, firewall, policy enforcement, email security, intrusion detection, authentication, and more.

- **Cloud Deployment Models**
  - **Private Cloud**
    - Provisioned for the exclusive use of a single organization.
    - Considerations - Scalability
    - It may be owned, managed, and operated by the organization, a third party, or some combination of them, and it may exist on or off-premises
  - **Community Cloud**
    - Community cloud infrastructure is provisioned for exclusive use by a specific community of consumers from organizations that have shared concerns.
    - It may be owned, managed, and operated by one or more of the organizations in the community, a third party, or some combination of them, and it may exist on or off-premises.
  - **Public Cloud**
    - The public cloud infrastructure is provisioned for open use by the general public. It may be owned, managed, and operated by a business, academic, or government organization, or some combination of them
    - It Exists on the premises of a cloud provider.
  - **Hybrid Cloud**
    - The hybrid cloud infrastructure is a composition of two or more distinct cloud infrastructures (private, community, or public) that remain unique entities but are bound together by standardized or proprietary technology that enables data and application portability (e.g., cloud bursting for load-balancing between clouds).
- **Cloud Access Security Broker**
  - Cloud access security broker (CASB) is a software tool or service that sits between an organization's on-premises infrastructure and a cloud provider's infrastructure.
  - A CASB acts as a gatekeeper, allowing the organization to extend the reach of its security policies beyond its infrastructure.
  - It helps organization extend on-premise controls or transform controls to various cloud
  - CASB discover unauthorized attempts to access private data
  - **CASB Provide visibility**
  - It provides the first measure of visibility into all the cloud applications being used by an organization.

- CASB help how cloud solutions and services align with the organization own established workflow
- CASB offers a single platform for extending or enhancing your security posture for data and assets in the cloud.

- **Cloud Base Vulnerabilities**
  - Big consent Multi-tenant
  - Need to have encryption.
  - Inherently exposed to external communication/access:
    - By their nature, cloud systems tend to be more exposed to external communications.
  - Misconfiguration a major risk
    - Cloud providers typically have a well-managed infrastructure, but unfamiliarity with the interface and management functions often results in users misconfiguring the cloud service or hosted components in a way that exposes data.
  - May exist for long periods (risk of being outdated)
    - Services ported to cloud environment may exist for a long period of time.
  - Gap between CSP and data owner security controls
    - There is a high risk for misunderstanding on the cloud customer's part where the responsibilities of the CSP end for security and the customer responsibilities begin.
- Mitigations
  - A reputable cloud service provider that supplies security information/testing results
  - Well trained system administrators
  - Robust configuration control/change control
  - File and communication encryption
  - Well managed identity and access control
- NIST SP 800146 lists the following benefits of SaaS deployments:
  - Very modest software tool footprint
  - Efficient use of software licenses
  - Centralized management and data
  - Platform responsibilities managed by providers
  - Savings in upfront
  - Costs
- NIST SP 800146 lists the following issues and concerns of SaaS deployments:
  - Browser-based
  - risks and risk remediation
  - Network dependence
  - Lack of portability between SaaS clouds
  - Isolation vs. efficiency (security vs. cost tradeoffs)
- The issues and concerns of IaaS deployments are as follows:
  - Compatibility with legacy security vulnerabilities
  - Virtual machine sprawl
  - Verifying the authenticity of an IaaS cloud provider website
  - Robustness of VM level
  - isolation
  - Features for dynamic network configuration for providing isolation
  - Data erase practices

- NIST SP 800146
  - lists the following benefits of IaaS deployments:
  - Full control of the computing resource through administrative access to VMs
  - Flexible, efficient renting of computing hardware
  - Portability, interoperability with legacy applications
- Virtual desktop infrastructure (VDI) is a means to reduce the security risk and performance requirements of end devices by hosting desktop/workstation OS virtual machines on central servers that are remotely accessed by users
- VM escaping occurs when software within a guest OS is able to breach the isolation protection provided by the hypervisor in order to violate the container of other guest OSs or to infiltrate a host OS.

- **Scalability and Elasticity**
  - **Scalability refers to the ability of a system to handle additional workloads by adding additional resources. As an example, imagine a server has 16 GB of random access memory (RAM), but it can support 64 GB of RAM. It's possible to shut down the server and add additional RAM to scale it up.**
  - **Elasticity refers to a system's ability to add and remove resources dynamically, based on increasing or decreasing load. As an example, imagine an e-commerce server with 16 GB of RAM and a four-core processor**
  - **Key point is that elasticity methods don't require shutting a system down to add the resources. The resources are automatically added or removed to match the demand. In contrast, scalability methods are not automatic or dynamic.**
    - **They require manual intervention to add additional resources, such as an administrator shutting down a system to add more RAM.**

Cloud Computing Disadvantage

- System Complexity
- Internet Facing services
- Share Multi-Tenant Environment
  - Delivery is done over the web
  - Loss of Control
    - Control transferred to a service provider
    - Lost of control over the physical & logical aspects
    - Security and Privacy could be a challenge

- 

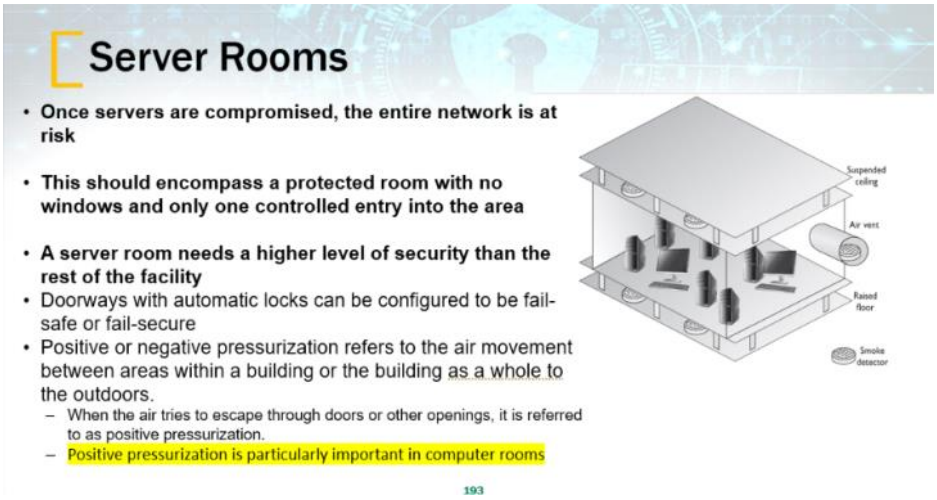
- **Edge and Fog Computing**
  - Edge computing is a philosophy of network design where data and the compute resources are located as close as possible in order to optimize bandwidth use while minimizing latency.
  - Edge computing can be viewed as the next evolution of computing concepts
  - Fog computing is another example of advanced computation architectures, which is also often used as an element in an IIoT deployment.
  - Fog computing relies on sensors, IoT devices, or even edge computing devices to collect data, and then transfer it back to a central location for processing.
  - One potential use for edge devices is the deployment of mini-web servers by ISPs to host static or simple pages for popular sites that are located nearer to the bulk of common visitors than the main web servers. This speeds up the initial access to the front page of a popular organization's web presence, but then subsequent page visits are directed to and served by core or primary web servers that may be located elsewhere.
  - The fog computing processing location is positioned in the LAN
  - In short, edge computing performs processing on the distributed edge systems, whereas fog computing performs centralized processing of the data collected by the distributed sensors. Both edge and for computing can often take advantage of or integrate the use of microcontrollers, embedded devices, static devices, cyber-physical systems, and IoT equipment.

- **Mobile System**
  - **Assess and Mitigate Vulnerabilities in Mobile Systems**
    - Vulnerabilities
      - For most mobile device types:
      - Loss or theft
      - Weak access controls configure
      - Unencrypted data
      - Communication interception or eavesdropping
      - Limited onboard security services and monitoring
  - **Mitigations**
    - **Mitigations for embedded type mobile devices without a full-featured OS:**
      - **Mobile device management (MDM) installed and managed centrally**
      - **Device tracking, wiping, software control, policy enforcement**
      - **Activate screen lock and high complexity passcodes or biometrics**
      - **Ensure the device is encrypted**
      - **Tunnel communications through a virtual private network (VPN) architecture**
      - **Limit software/apps installed to trusted packages**
      - **Prevent jailbreak or rooting devices as this bypasses most built-in security functions and leaves the device susceptible to both local access and network-based attacks**
      - **Do not connect to public networks (e.g., coffee shop, hotel)**
      - Data encryption, idle timeout locks, screen-saver lockouts, authentication, and remote wipe should be enabled
      - Prevent jailbreak or rooting devices
      - Implement Device lockdown and perimeter control and filtering should be put into place and

monitored
    - **For laptops or hybrid systems with a full-featured OS:**
        - **Apply all traditional computer system protections (e.g., AV, FW, Host IPS, etc.)**
        - **Ensure encryption is activated**
        - **Ensure strong passwords, biometrics, or two-factor authentication on all user accounts**
        - **Activate anti-theft function or tracking functions if available (available on many business-class systems and some personal class systems)**
        - **Tunnel mobile communications through VPN**
- Content Management
    - Content management is the control over mobile devices and their access to content hosted on company systems as well as the control of access to company data stored on mobile devices.
    - The goal of a content management system (CMS) for mobile devices is to maximize performance and work benefit while reducing complexity, confusion, and inconvenience. An MCM may also be tied to an MDM to ensure secure use of company data.
    - MCM (mobile content management) system is used to control company resources and the means by which they are accessed or used on mobile devices
    - Mobile application management (MAM) is similar to an MDM but focuses only on app management rather than managing the entire mobile device
    - Corporate-Owned Mobile Strategy (COMS)
        - A corporate-owned mobile strategy (COMS) or corporate-owned, business-only (COBO) strategy is when the company purchases the mobile devices that can support security compliance with the security policy.
        - 

- **Data Center**
    -

TIER LEVEL	AVAILABILITY %	REDUNDANCY
1	99.671	None. Multiple single points of failure.
2	99.741	Some. Nonredundant (e.g., N) UPS.
3	99.982	N+1 UPS. Able to take equipment out of service for maintenance without affecting operation.
4	99.995	2N UPS. No single point of failure, able to automatically compensate for any single failure.



- **Apply Security Principles to Site and Facility Design**

  Security needs to protect all the assets of the organization and enhance productivity by providing a secure and predictable environment

  objectives of the site and facility security program depend upon the level of protection required for the various assets and the company as a whole

  - The primary goal of the plan should be to protect human life.
  - Physical Security
    - Physical security plans and infrastructure are often designed, implemented, and operated by physical security specialists in larger organizations.
    - Physical security infrastructure is typically controlled outside of IT or IT security control in larger organizations.

      Physical design should support confidentiality, integrity, and availability of information systems and must consider human safety and external factors as well
  - **CISSP MUST understand physical security fundamentals in order to do the following:**
    - Assess the risk reduction value of physical security controls
    - Communicate physical security needs to physical security managers
    - Identify risks to Information Security due to physical security weaknesses

- Security Assessment
  - A comprehensive overview of physical security controls, policy, procedure, and employee safety.
- Internal Security Controls
  - Controls for human safety
    - Visible and audible alarms, fire suppression, Response plans/training, emergency shutoffs.
  - Controls to manage access
    - Door locks, Access point security, Multifactor access.
  - Internal Monitoring
    - Physical access control system/Monitor
    - Video Surveillance
    - RF Monitoring
- Implement and Manage Physical Security
  - Conduct a physical risk assessment
    - Human action, Natural Disaster, Industrial Accident, equipment failure etc.

- Develop layered physical protections commensurate with risk assessment
- Physical risk controls will impact information system design.
- Physical protections required monitoring and auditing.

○ Perimeter Security controls



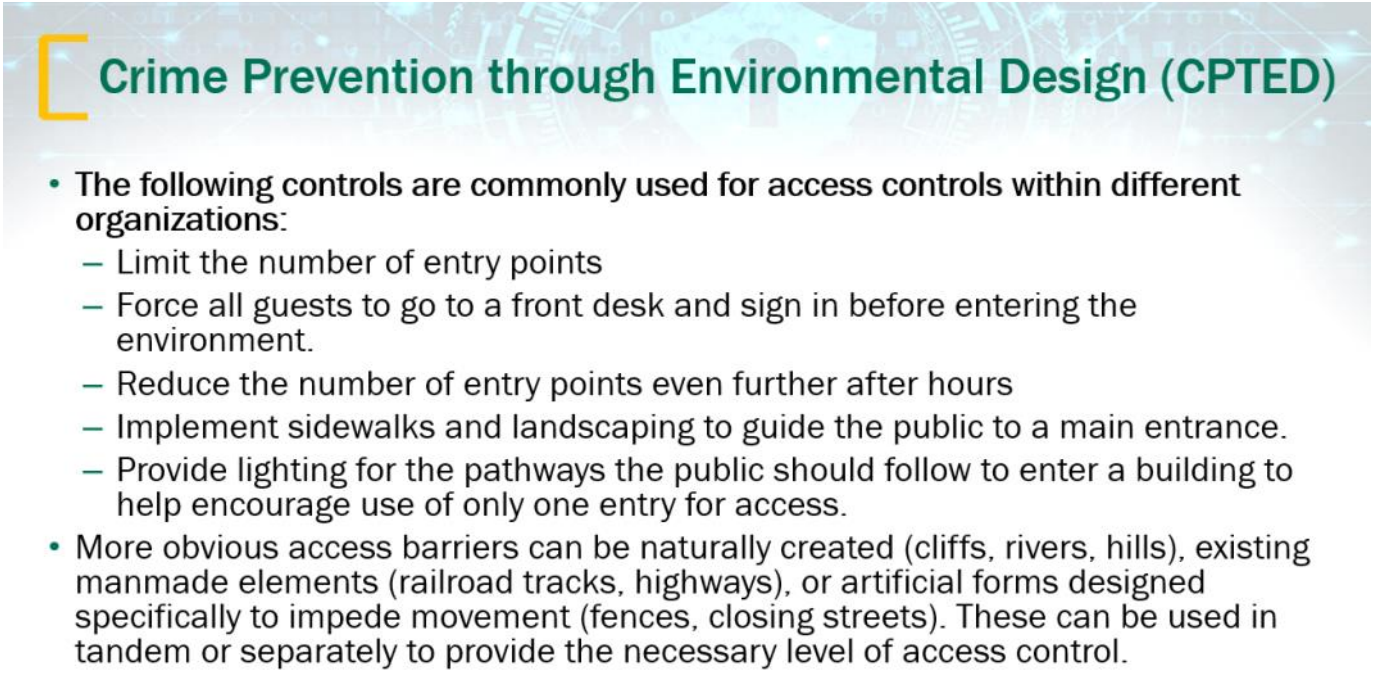
- **Surrounding areas** concerns include the following:
  - Roadways: Roads close to or adjacent to the site.
  - Waterways: Adjacent or crossing the site. This may include navigable waterways or small drainage features if they impact the site security
  - Geography: Terrain of the site in terms of potential visibility limits, concealment opportunities, or natural barriers to entry
  - Lines of sight: Areas, where visibility is limited by features or structures, is a concern
  - Associated considerations include the following:
    - Is the facility visible from roads?
    - Is there a potential for vehicle-borne threats?
    - Where are the vehicular and pedestrian access points?
    - Is there adequate fencing, or impassible perimeter landscaping (natural fence)?
- **Site entry and exit points** include the following:
  - Vehicular: Are vehicular access points protected against credible vehicular threats?
  - Public/customer/visitor: Are there separate entry controls for public, customer, or visitor access?
  - Staff/employee: Do staff or employees have dedicated controlled access points?
  - Delivery/truck: Is there a delivery or truck entrance, and how is it controlled?
  - Pedestrian: Are there controlled pedestrian entry points to the site?
  - **Considerations for site entry and exit:**
    - **Access controls: What are the access controls to enter or leave the site—badge, proximity card, guard monitored?**
    - **Surveillance: Is there sufficient surveillance capability to cover site entry and exit points?**
    - **Lighting: Is lighting sufficient to allow humans or video systems to adequately make subject identification in all light conditions?**
    - **Intrusion detection: Are sensors or intrusion detection devices installed on unattended or unmonitored access points?**
    - **Barriers/traffic control: Are barriers in place or available for traffic control at any or all of the vehicular access points?**
- **External facilities** that include the following:
  - Parking structures/lots

- Utility components
- Electric transformers/lines
- Telecommunications
- Landscaping
- For these consider the following:
  - Lighting: Does the lighting provide sufficient lighting under all conditions for human and/or video identification of subjects? Does the lighting limit shadow areas or areas of no visibility during darkness?
  - Surveillance: Does surveillance cover areas where security or human safety is a concern?
  - Intrusion detection: Are alarms or sensors installed in unattended external buildings or facilities?
  - Lines of sight: Are lines of site sufficient and dead space eliminated?

- **Operational Facilities** are the following:
  - Where employees work
  - Where IT operates
  - For these consider the following:
    - Exterior lighting and surveillance: Appropriate to expected threats. Lighting is of sufficient brightness and coverage to limit shadows and make human or video identification of subjects possible.
    - Building materials: Appropriate for the level of security required.
    - Doors, windows, walls: Are of the appropriate type and security level to mitigate expected risks.
    - Entry/exit points and access controls: Unattended access conditions, guard monitoring, video monitoring.
    - Staff/employee entrance: Is there a staff-only entrance, and how is it controlled? Attended, unattended?
    - Public/customer entrance: Is there a public or customer entrance with different security needs from the staff entrance?
    - Delivery entrance: Is there a loading dock or delivery facility?
    - Sensors/intrusion detection: Have sensors or alarms been installed on doors and windows?

- **Crime Prevention Through Environmental Design (CPTED)**
  - Discipline that outlines how proper design of physical environment can reduce crime by directly affecting human behavior
  - CPTED considers how the environment can influence human behavior and reduce potential crime
  - It provides guidance in loss and crime prevention through proper facility construction and environmental components and procedures.
  - Target hardening focuses on denying access through physical and artificial barriers
  - **CPTED provides three main strategies to bring together the physical environment and social behavior to increase overall protection**
    - Natural access control
      - guidance of people entering and leaving a space
    - Natural surveillance
      - goal of natural surveillance is to make criminals feel uncomfortable and maximize visibility
    - Natural territorial reinforcement
      - goal of territorial reinforcement is to create a sense of a dedicated community
  - **The CPTED process provides direction to solve the challenges of crime with:**

- Organizational (People)
- Mechanical (Technology and Hardware)
- Natural Design (Architecture and Circulation Flow) Methods.



- Typical Perimeter Control Types
  - Lighting
    - Lighting for personnel safety and intruder deterrence
      - Intruders are less likely to enter well-lit areas
      - Lighting can be continuous, motion-triggered, random, timed, or standby
      - Lighting should be tamper-proof and have a backup power supply
    - **Perimeter Lighting - Deterrence Control**
      - Continuous lighting - Light that is always illuminated
      - Standby lighting - lights programmed to turn on/off at certain times
      - Motion Activated lighting - activate lights after detecting movement in the coverage area.
    - Bright enough to cover target areas
    - Limits shadow areas
    - Sufficient for the operation of cameras, must be coordinated with camera plan
      - Lighting levels - At least 10-12ft
      - Candles over parked cars.
      - 15 to 20 ft candles in the walking and driving aisles
  - Surveillance/Camera
    - Surveillance technologies such as IDS/IPS, closed-circuit TV (CCTV) and camera systems can be used to monitor, detect (and report) suspicious, abnormal, or unwanted behavior.
    - Narrow focus for critical areas
    - Wide focus for large areas
    - IR/low light in unlit areas
    - Monitored and/or recorded

- Dummy cameras (Type of deterrent controls)
- Intrusion Detection
  - Cut/break sensors
  - Sound/audio sensors
  - Motion sensors

- Barriers
  - Fixed barriers to prevent ramming
  - Fixed barriers to slow speeds
  - Deployable barriers to block access ways
  - Fencing/Security landscaping
  - Slows and deters Should not impede monitoring
- Windows
  - Windows should not be placed adjacent to doors
  - Use laminated glass in place of conventional glass
  - Windows on the ground level should not have the ability to open
  - The alerts available for a window include a magnetic switch
- Building Material security examples:
  - High-security glass
  - Steel/composite doors
  - Steel telecommunications conduit
  - Secure walls
  - True floor to ceiling walls (wall continues above drop ceiling)
  - Anchored framing material
  - Solid walls/in-wall barriers
- **Lock security examples:**
  - Available in varying grades
  - Physical key locks
  - Mechanical combination locks
  - Electronic combination locks
  - Biometric locks
  - Magnetic locks
  - Magnetic stripe card locks
  - Proximity card locks
  - Multi-factor locks (e.g., card + pin)
- Internal Security Controls
  - Controls for human safety
    - Visible and audible alarms, fire suppression, response plans/training, emergency shutoffs
- Controls to manage access
  - Door locks (e.g., magnetic, card key, mechanical key, combination lock)
  - Access point security (e.g., mantraps, limited ingress, alarmed emergency egress)
  - Multifactor access (e.g., key card + pin for room entry)
- Internal monitoring
  - Physical access control system/monitor (e.g., records key card use)

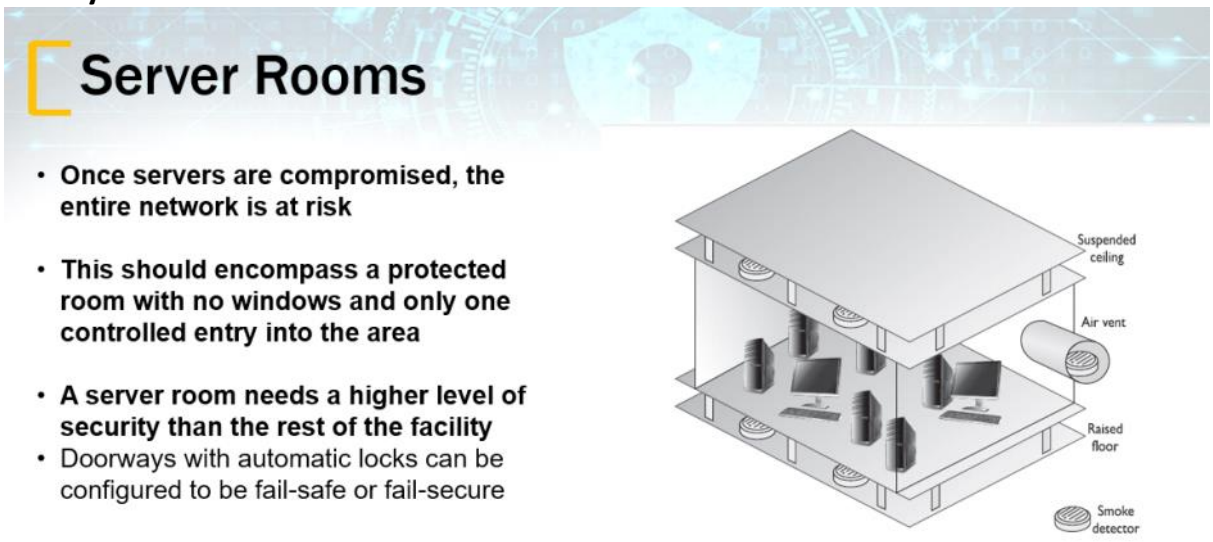
- Video surveillance/cameras
- Radio Frequency (RF) monitoring

- Signs
  - Signs for personnel safety and intruder deterrence
    - Warning signs indicate surveillance (“someone is paying attention”)
- Security Guards
  - Security personnel may be stationed at checkpoints, patrol the area, manage surveillance, and respond to breaches and/or suspicious activity.
- **Glass Break**
  - Types of Glass
    - Tempered Glass
    - Wired Glass
    - Laminated glass
    - Bullet resistant (BR) glass
  - Glass Break Sensors
    - Good intrusion detection device for buildings with a lot of glass windows and doors with glass panes
    - The use of dual- technology glass break sensors and shock wave - is most effective
- Wiring Closets
  - Wiring closets are small room or closet areas where telecommunications mediums connect to facility infrastructure.
- Fire Suppression
  - Human training and awareness is critical to fire prevention
  - Fire Suppression (it’s a corrective Control)
    - Buildings should be equipped with one or more types of fire suppression systems.
- Water-based
  - Effective for common material fires (e.g., wood, paper, building materials)
  - Safe for human spaces
  - Damages equipment
  - Ineffective for electrical or petroleum fires
  - Typically cheaper than gas-based
- Gas-based
  - Effective for any fire type
  - Typically safe for equipment
  - It may be dangerous to humans in enclosed spaces (depending on the type)
  - Costly to install and maintain compared to water-based
- Water can be the main fire suppression tool; However, it will cause extreme damage to electronic equipment.
  - Fire extinguishers are divided into four categories based on different types of fires:
    - Class A : Ordinary Combustible materials
      - Paper, Wood & Plastic (Out of paper, wood and plastic is Ash)
    - Class B : Flammable Or Combustible liquids
      - Boil Gasoline, carnosine, grease, and oil

- Class C : Electrical Equipment
  - Wires, Current
- Class D : Combustible Metals
  - Dilute - meter, copper, silver, and gold, metal

Fire Class	Type of Fire	Elements of Fire	Suppression Method
A	Common combustibles	Wood products, paper, and laminates	Water, foam
B	Liquid	Petroleum products and coolants	Gas, CO_2, foam, dry powders
C	Electrical	Electrical equipment and wires	Gas, CO_2, dry powders
D	Combustible metals	Magnesium, sodium, potassium	Dry powder

- **Fire Prevention & Detection**
  - Smoke detector is one of the most important devices, sound an alarm and give humans make it out alive
  - The first rule of fire protection is fire prevention. Local fire codes specify the fire prevention practices required or expected by the community.
  - Periodic fire drills are one typical requirement.
  - Other requirements might include:
    - The elimination of storage items and trash in fire stairwells.
    - Not storing fuel or volatile chemicals near paper or rags, or in a closed area where combustible fumes can collect.
    - The specifications of fire extinguisher types used in a facility.
    - The type of fire suppression system used in a building.
    - Maximum permitted occupancy in a room.
    - Leaving exits unblocked.
    - Leaving emergency exit doors unlocked during business hours
  - Gas suppression systems operate to starve oxygen - Aero - K and FM-200, it doesn't displace the oxygen and leaves no residue FM-200 is better than Aero-K.
  - FE-13 safer than FM 200
  - **HALON is very Dangerous**
- Wiring Closets/Intermediate Distribution Facilities
  - Entrance facility
    - External communications enter a facility
    - Phone, network, special connections
    - May house internet service provider (ISP) or telecommunications provider equipment
- Equipment room
  - Primary communication hub for facility
  - Houses wiring/switch components
  - It may be combined with entrance facility
  - Backbone distribution
  - Connects entrance facility, equipment room, and telecommunication room(s)
- Telecommunications room (wiring closet)
  - Serves a particular area of a facility

    - Floor, section, wing, etc.
    - Terminates local wiring into patch panels
- Backbone distribution is broken out into individual connections (e.g., switch)
    - Horizontal Distribution System
    - Cables, patch panels, jumpers, cable
- **Security protections** for the overall cable plant:
    - Rooms must be secured against unauthorized access
    - Access to rooms should be monitored/recorded
    - Secondary locks on equipment/racks
    - Rooms may share space with non-IT equipment and require access by non-IT staff
    - Conduit or tamper protections for wiring
- Environmental protection for the cable plant:
    - Protection from lightning/surge
    - Backup power/uninterruptible power supply (UPS)
    - Heating/cooling/airflow
    - Critical in enclosed spaces
    - Appropriate fire detection/suppression
    - Emergency shutoffs for high power connections
    - May not be necessary for all closets
- Server Rooms/Data Centers
    - Similar security and environmental protections to wiring closets.
    - Access point security and access monitoring must be in place.
    - Power, surge protection, and uninterruptible power supplies (UPS) must be tailored to the operating equipment and of sufficient capacity.
    - Human safety becomes an issue with power levels in most server rooms and emergency shutoffs, and non-conductive hooks/gloves become important for human safety.
- **Server rooms are typically maintained at a higher level of physical security than the rest of the facility**
- 

- **Data Center Security**

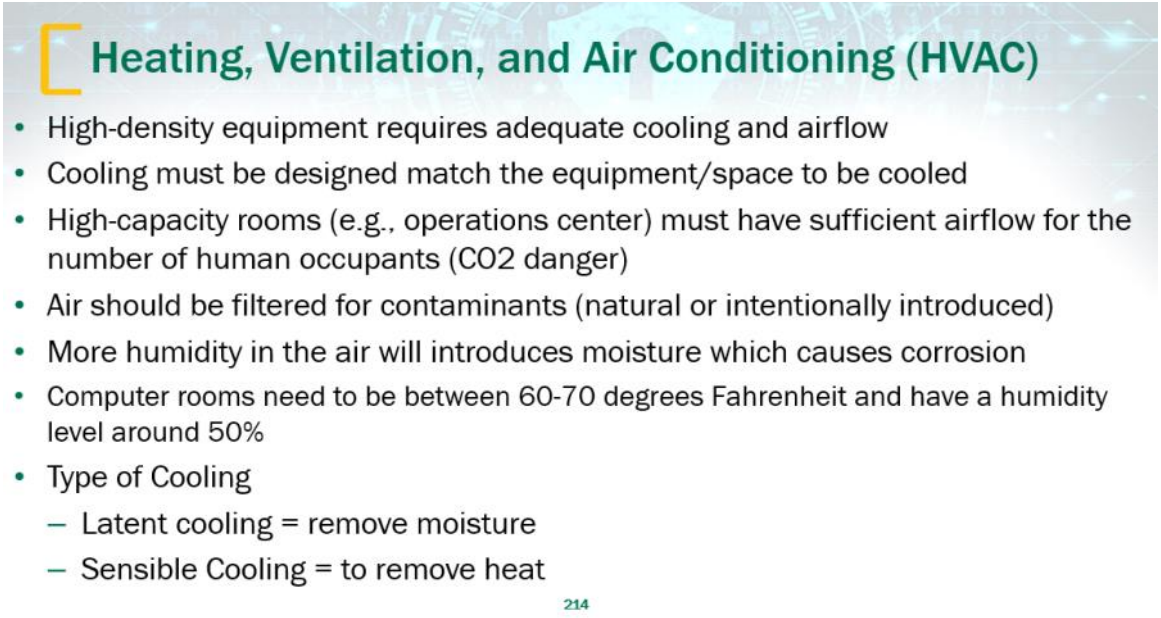
- Portal - Prevent Tailgating
- The "Two-Person" Rule

Turnstile

• Form of door that prevents more than one person entering at a time • Coupled with security guards/access control helps prevent un-authorized entry into facility • Can prevent tailgating

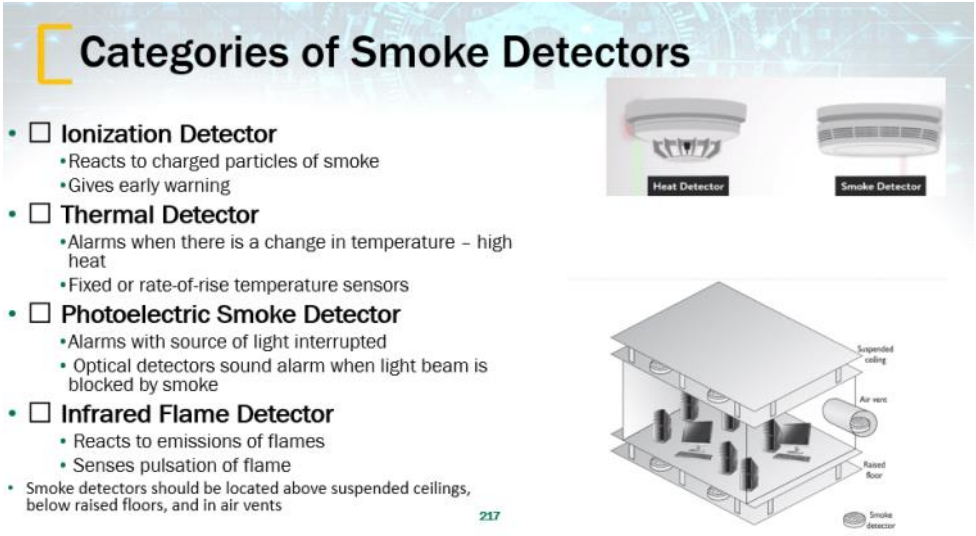
Mantrap

• A set of double doors often protected by a guard • The first door is provided access for entry, once the person passes the first door and enters, the first door closes; the person has to authenticate again at the second door to get access • This prevents piggybacking and tailgating



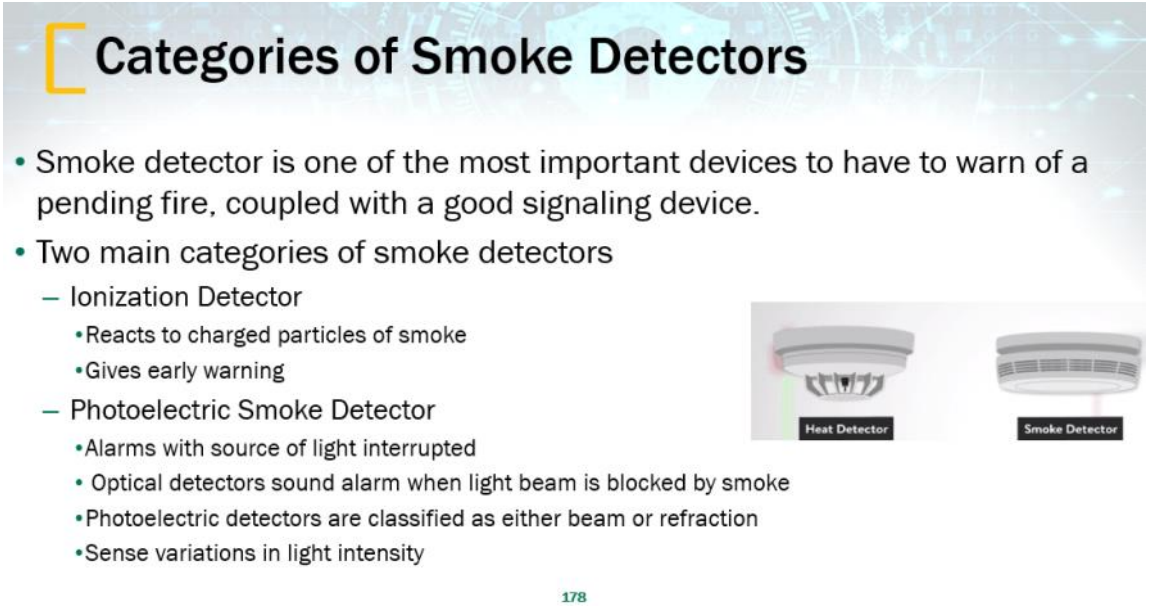
- NOC and SOC
  - Availability and confidentiality and integrity
- Utilities and Power
  - Data centers are built with both batteries and generators, Generator should be active up to speed within 10 seconds of power failure. Minimum fuel at least 12 hours
  - UPS (Uninterruptible Power Supply)
- HVAC (Heating, Ventilation, and Air Conditioning)
  - High-Density Equipment requires adequate cooling and airflow
  - All computer equipment has a range of acceptable operating temperatures
  - High-density equipment and equipment within enclosed spaces require adequate cooling and airflow.
  - Cooling must be designed to match the equipment and space to be cooled.
- Optimal Temperature
  - Optimal air temperature in working areas for personal is typically 65 to 75 degrees Fahrenheit.
  - Computer rooms need to be between 60-70 degree Fahrenheit and have a humidity level of around 50%
  - **More humidity in the air will introduce moisture which causes corrosion.**
  - **Low humidity in the air will cause static electricity**
- Power Issues
  - Power Surge - Long period of high voltage

- Power Fault - Temporary loss of power
- Power Blackout - Complete loss of power
- Power Brownout - Long period of low power voltage
- Power Dip/Sag - Temporary period of low power voltage
- Power Spike - Temporary period of high-power voltage



- A smoke detector is one of the most important devices to have to warn of a pending fire, coupled with a good signaling device.
  - A detector in proper working condition will sound an alarm and give all occupants a chance to make it out alive. There are two main categories of smoke detectors: optical detection (photoelectric) and physical process (ionization).
  - Photoelectric detectors are classified as either beam or refraction. Beam detectors operate on the principle of light and a receiver. Once enough smoke enters the room and breaks the beam of light, the alarm is sounded. The refraction type has a blocker between the light and the receiver. Once enough smoke enters the room, the light is deflected around the beam to the signal. The ionization type detector monitors the air around the sensors constantly. Once there is enough smoke in the room the alarm will sound
  - Properly protecting a facility from fire requires installing an automated detection and suppression system
- **Stages of fire**
  - Stage 1: Incipient - only air ionization, no smoke
  - Stage 2: Smoke - Smoke is visible from the point of ignition
  - Stage 3: Frame - Flame is visible from the naked eye
  - Stage 4: Heat - fire is considerably higher
- **Security Guards and Guard Dogs**
  - Security guards are often an appropriate security control when immediate situation handling and decision making on site is necessary.
  - Guard dogs can be an alternative to security guards. They can often be deployed as a perimeter security control. As a detection and deterrent, dogs are extremely effective. However, dogs are costly, require a high level of maintenance, and impose serious insurance and liability requirements.
  - Robot sentries can be used to automatically patrol an area to look for anything out of place.

- **Keys and Combination Locks**
  - These types of locks are subject to lock picking, which is often categorized under a class of lock mechanism attacks called shimming. Many conventional locks are also vulnerable to an attack known as bumping. Bumping is accomplished using a special bump key that when properly tapped or bumped causes the lock pins to jump and allows the cylinder to turn.
  - Programmable or combination locks offer a broader range of control than preset locks. Some programmable locks can be configured with multiple valid access combinations or may include digital or electronic controls employing keypads, smartcards, or cipher devices
  - Locks serve as an alternative to security guards as a perimeter entrance access control device.
- Smart Cardd
  - Badges, identification cards, and security IDs are forms of physical identification and/or electronic access control devices
  - Smartcards are credit card–sized IDs, badges, or security passes with an embedded magnetic stripe, bar code, or integrated circuit chip.
    A smartcard may be known by several phrases or terms:
    ■■ An identity token containing integrated circuits (ICs)
    ■■ A processor IC card
    ■■ An IC card with an ISO 7816 interface



Fire detectors

- Flame Detector
  - Infrared (IR) Detector
    - large mass of hot gases that emit a specific spectral pattern
  - Ultraviolet (UV) detectors
    - detect flames at speeds of 3 to 4 milliseconds due to the high-energy radiation emitted by fires
- Heat Detector
  - fixed-temperature or rate-of-rise detectors.



Infrared (IR) Detector



Ultraviolet (UV) detectors



Heat Detector

179

- **Water based Fire Suppression**

Type	Functionality	comment
Wet-pipe	It is always full of water, usually discharged by temperature control sensors Also called closed head systems	Water may freeze in colder temperatures A damage in nozzle or pipe can result in leak
Dry Pipe	Water is not stored in pipe, instead contains compressed air. Opening the water valve cause water to fill the pipes and discharge	Best suited for colder climates
Preaction	Combination of wet and dry pipe; water is not held in pipes until fire is detected; it is released only after the sprinkler head activation triggers are melted by sufficient heat;	Used in data processing equipment's
Deluge	Another form of dry pipe system that uses larger pipes and can deliver significantly larger volume of water	Inappropriate for environments that contain electronic equipments